Informe de Post-Incidente

Hardening:
Servidor WEB

Realizado por:
Anied Arpisa

Hardening: Servidor WEB

Equipos afectados: Servidor Web (HTTP) - 192.168.0.137
Propósito: Detallar las vulnerabilidades halladas y las contramedidas aplicadas para mitigar riesgos futuros.

Resumen:
Se detectó que el servidor web de la empresa 4Geeks Academy presentaba múltiples brechas de seguridad, las cuales comprometían la disponibilidad, integridad y confidencialidad de la información y datos gestionados y almacenados.

Bitácora de correcciones:
En el marco de un proceso de Hardening, hemos llevado a cabo una serie de acciones importantes para reforzar la seguridad del servidor web. El instrumento utilizado para llevar a cabo estas acciones fue el Informe de Pentesting, el cual nos da una guía clara y detallada de las vulnerabilidades presentes en el equipo afectado.

Categoría	Estado Inicial	Acción Realizada
Contraseñas	Contraseña de usuario *debian* débil. Existente en los diccionarios de ataque de fuerza bruta.	Se reemplazó la contraseña actual por una más robuste que incluya dos características diferentes.
WEB	Conexión a web sin cifrar (Puerto 80 – http)	Creación y configuración de certificado para conexión cifrada y segura.
Acceso SSH	Conexión a usuario root permitido por SSH	Se bloqueó el acceso al usuario root por vía SSH.
Base de Datos	Cifrado débil, mysql SHA-1	Instalación de plugin de autenticación estándar ed25519.
Firewall	No existían reglas de filtrado en el Firewall	Se crearon las reglas necesarias para blindar el servidor y bloquear tráfico no autorizado.
Puertos	Puertos no necesarios en estado abierto.	Se detuvo los servicios asociados a esos puertos y se filtraron para evitar riesgos de seguridad.
Actualizaciones	Realizadas de forma manual.	Creación de tarea programada para la actualización automática del servidor.
Permisos	Directorios con información sensible con permisos 777	Configuración de permisos basada en el Principio de Menor Privilegio.

Anexos:

Cambio de claves de usuario:

```
debian@debian: ~
File  Edit  View  Search  Terminal  Help
debian@debian:~$ passwd
Changing password for debian.
Current password:
New password:
Retype new password:
passwd: password updated successfully
debian@debian:~$
debian@debian:~$
debian@debian:~$
debian@debian:~$ sudo passwd root
[sudo] password for debian:
New password:
Retype new password:
passwd: password updated successfully
debian@debian:~$
debian@debian:~$
debian@debian:~$
debian@debian:~$
```

- **Creación y configuración de certificado para conexiones seguras:**

- Generar una clave privada RSA de 2048 bits:

```
debian@debian:~$ sudo openssl genrsa -out /etc/ssl/private/myserver.key 2048
[sudo] password for debian:
```

- Verifica que el archivo se creó:

```
debian@debian:~$ sudo ls -l /etc/ssl/private/myserver.key
-rw------- 1 root root 1704 Mar 11 10:25 /etc/ssl/private/myserver.key
```

- Generación de un CSR que contendrá la información pública que se incluirá en el certificado:

```
debian@debian:~$ sudo openssl req -new -key /etc/ssl/private/myserver.key -out /etc/ssl/certs/myserver.csr
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:VE
State or Province Name (full name) [Some-State]:Caracas
Locality Name (eg, city) []:Caracas
Organization Name (eg, company) [Internet Widgits Pty Ltd]:MiProyecto
Organizational Unit Name (eg, section) []:IT
Common Name (e.g. server FQDN or YOUR name) []:mi-proyecto.com
Email Address []:admin@mi-proyecto.com
```

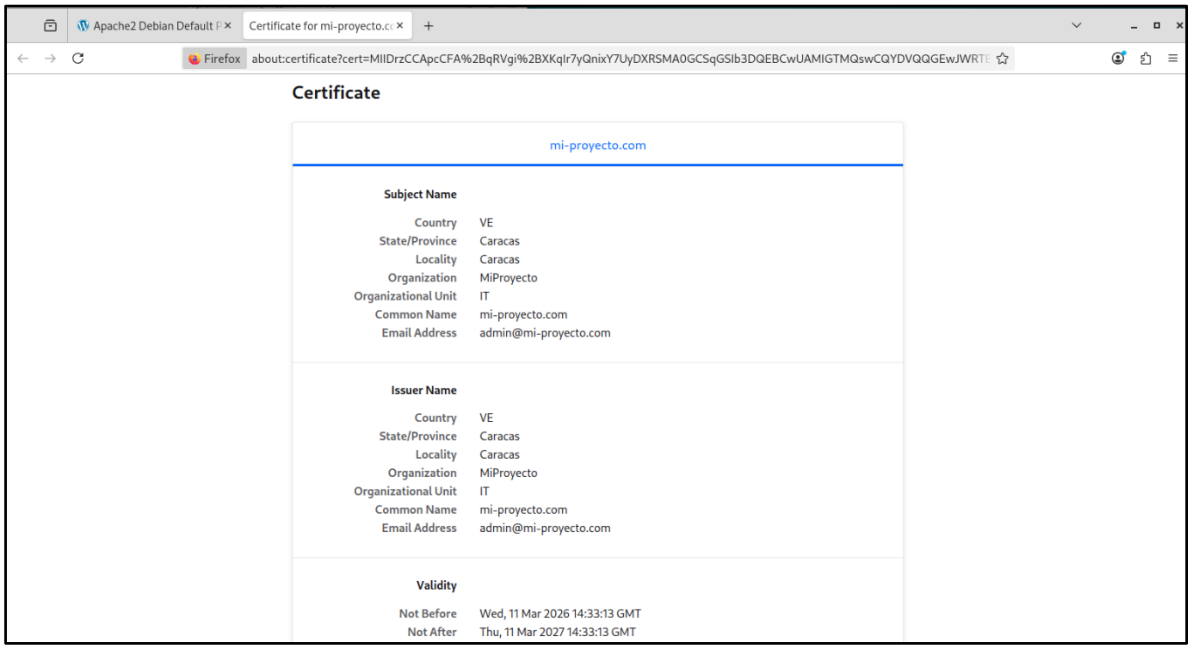
- Firma del CSR para Obtener un Certificado Autofirmado:

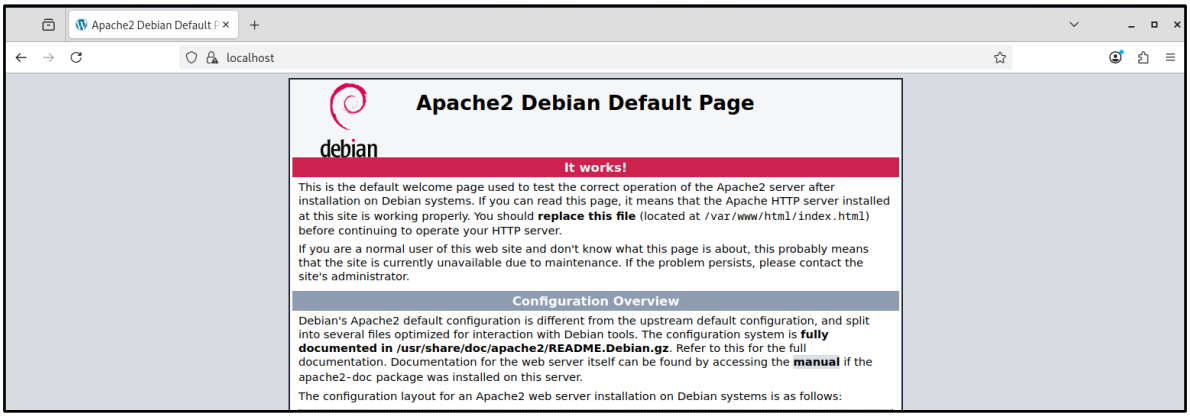
```
debian@debian:~$ sudo openssl x509 -req -days 365 -in /etc/ssl/certs/myserver.csr -signkey /etc/ssl/private/
myserver.key -out /etc/ssl/certs/myserver.crt
Certificate request self-signature ok
subject=C = VE, ST = Caracas, L = Caracas, O = MiProyecto, OU = IT, CN = mi-proyecto.com, emailAddress = adm
in@mi-proyecto.com
debian@debian:~$
```

- Configuración de Apache para Usar el Certificado SSL

- Activación del módulo SSL y carga de la configuración del sitio HTTPS

```
debian@debian:~$ sudo a2enmod ssl
Considering dependency setenvif for ssl:
Module setenvif already enabled
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Enabling module socache_shmcb.
Enabling module ssl.
See /usr/share/doc/apache2/README.Debian.gz on how to configure SSL and create self-signed certificates.
To activate the new configuration, you need to run:
  systemctl restart apache2
debian@debian:~$
debian@debian:~$ sudo a2ensite default-ssl
Enabling site default-ssl.
To activate the new configuration, you need to run:
  systemctl reload apache2
debian@debian:~$
debian@debian:~$ sudo systemctl reload apache2
```





- Adicionalmente, se configuró que el tráfico entrante por el puerto 80 sea redirigido al puerto cifrado 443.

```
  GNU nano 7.2      /etc/apache2/sites-available/000-default.conf
<VirtualHost *:80>
        # The ServerName directive sets the request scheme, hostname and port t
        # the server uses to identify itself. This is used when creating
        # redirection URLs. In the context of virtual hosts, the ServerName
        # specifies what hostname must appear in the request's Host: header to
        # match this virtual host. For the default virtual host (this file) this
        # value is not decisive as it is used as a last resort host regardless.
        # However, you must set it for any further virtual host explicitly.
        #ServerName www.example.com

        ServerAdmin webmaster@localhost
        ServerName  mi-proyecto.com

        Redirect permanent / https://mi-proyecto.com/
        DocumentRoot /var/www/html
         <Directory /var/www/html>
                AllowOverride All
        </Directory>
```

- **Desactivar el acceso root por ssh:**

- Bloquear el acceso Root:

```
debian@debian: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 7.2                    /etc/ssh/sshd_config
#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

Prueba:

```
C:\Users\arpisa_unfpa>ssh root@172.16.16.19
root@172.16.16.19's password:
Permission denied, please try again.
root@172.16.16.19's password:
Permission denied, please try again.
root@172.16.16.19's password:
```

- **Cifrado de claves de usuarios de Base de Datos:**

```
debian@debian: ~
File  Edit  View  Search  Terminal  Help
MariaDB [(none)]> SELECT user, Host, plugin  FROM mysql.user;
+---------------+-----------+-----------------------+
| User          | Host      | plugin                |
+---------------+-----------+-----------------------+
| mariadb.sys   | localhost | mysql_native_password |
| root          | localhost | ed25519               |
| mysql         | localhost | mysql_native_password |
| wordpressuser | localhost | ed25519               |
+---------------+-----------+-----------------------+
4 rows in set (0.001 sec)

MariaDB [(none)]>
MariaDB [(none)]> SELECT user, Host, password  FROM mysql.user;
+---------------+-----------+----------+
| User          | Host      | Password |
+---------------+-----------+----------+
| mariadb.sys   | localhost |          |
| root          | localhost |          |
| mysql         | localhost | invalid  |
| wordpressuser | localhost |          |
+---------------+-----------+----------+
4 rows in set (0.000 sec)

MariaDB [(none)]>
```

- Creación de reglas de firewall con IPTABLES:
  - Creación de reglas para el filtrado de tráfico

```
debian@debian: ~
File  Edit  View  Search  Terminal  Help
debian@debian:~$
debian@debian:~$
debian@debian:~$ sudo iptables -L
Chain INPUT (policy DROP)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere             ctstate RELATED,ESTABLISHED
ACCEPT     tcp  --  192.168.0.0/24       anywhere             tcp dpt:ssh
ACCEPT     tcp  --  172.16.16.0/24       anywhere             tcp dpt:ssh
SYN_FLOOD  tcp  --  anywhere             anywhere             tcp flags:FIN,SYN,RST,ACK/SYN
DROP       tcp  --  anywhere             anywhere             tcp flags:FIN,SYN,RST,PSH,ACK,URG/NONE
DROP       tcp  --  anywhere             anywhere             tcp flags:FIN,SYN,RST,PSH,ACK,URG/FIN,SYN,RST,PSH,AC
K,URG
REJECT     tcp  --  anywhere             anywhere             tcp dpt:http #conn src/32 > 20 reject-with icmp-port
-unreachable
ACCEPT     tcp  --  anywhere             anywhere             tcp dpt:http
ACCEPT     tcp  --  anywhere             anywhere             tcp dpt:https

Chain FORWARD (policy DROP)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere

Chain SYN_FLOOD (1 references)
target     prot opt source               destination
RETURN     all  --  anywhere             anywhere             limit: avg 1/sec burst 3
DROP       all  --  anywhere             anywhere
debian@debian:~$
```

  - Suspensión de procesos activos no utilizados

```
debian@debian:~$ ss -tunap
Netid State  Recv-Q Send-Q       Local Address:Port   Peer Address:Port Process
udp   ESTAB  0      0      172.16.16.19%enp0s3:68      172.16.16.1:67
udp   UNCONN 0      0                 0.0.0.0:49889       0.0.0.0:*
udp   UNCONN 0      0                 0.0.0.0:5353        0.0.0.0:*
udp   UNCONN 0      0                    [::]:57752          [::]:*
udp   UNCONN 0      0                    [::]:5353           [::]:*
tcp   LISTEN 0      128               0.0.0.0:22          0.0.0.0:*
tcp   LISTEN 0      80              127.0.0.1:3306        0.0.0.0:*
tcp   LISTEN 0      128             127.0.0.1:631         0.0.0.0:*
tcp   LISTEN 0      20              127.0.0.1:25          0.0.0.0:*
tcp   LISTEN 0      511                     *:443               *:*
tcp   LISTEN 0      128                  [::]:22             [::]:*
tcp   LISTEN 0      511                     *:80                *:*
tcp   LISTEN 0      20                  [::1]:25            [::]:*
tcp   LISTEN 0      128                 [::1]:631           [::]:*
debian@debian:~$
```

Prueba:

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 172.16.16.19
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-11 13:00 -0400
Nmap scan report for debian.lan (172.16.16.19)
Host is up (0.00084s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
MAC Address: 08:00:27:D4:3A:A5 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 106.95 seconds

┌──(kali㉿kali)-[~]
└─$
```

- Creación de regla para actualización automática del servidor:

```
debian@debian: ~
File  Edit  View  Search  Terminal  Help
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command

0 3 * * 0 apt-get update && apt-get upgrade -y >> /var/log/update_script.log 2>&1

debian@debian:~$
debian@debian:~$
```

- Corrección de permisos basados en el principio de meo privilegio

```
debian@debian:/var/www/html$ sudo chown -R www-data:www-data /var/www/html/
[sudo] password for debian:
debian@debian:/var/www/html$
debian@debian:/var/www/html$ sudo find /var/www/html/ -type d -exec chmod 755 {} \;
debian@debian:/var/www/html$
debian@debian:/var/www/html$ sudo find /var/www/html/ -type f -exec chmod 644 {} \;
debian@debian:/var/www/html$
debian@debian:/var/www/html$
debian@debian:/var/www/html$ sudo chmod 600 /var/www/html/wp-con
wp-config.php         wp-config-sample.php  wp-content/
debian@debian:/var/www/html$ sudo chmod 600 /var/www/html/wp-config.php
```

```
debian@debian:/var/www/html$ ls -la
total 264
drwxr-xr-x  5 www-data www-data  4096 Mar 10 23:25 .
drwxr-xr-x  3 root     root      4096 Sep 30  2024 ..
-rw-r--r--  1 www-data www-data   523 Sep 30  2024 .htaccess
-rw-r--r--  1 www-data www-data 10701 Sep 30  2024 index.html
-rw-r--r--  1 www-data www-data   405 Feb  6  2020 index.php
-rw-r--r--  1 www-data www-data 19903 Feb 23 21:20 license.txt
-rw-r--r--  1 www-data www-data  7425 Mar 10 23:25 readme.html
-rw-r--r--  1 www-data www-data  7349 Feb 23 21:20 wp-activate.php
drwxr-xr-x  9 www-data www-data  4096 Sep 10  2024 wp-admin
-rw-r--r--  1 www-data www-data   351 Feb  6  2020 wp-blog-header.php
-rw-r--r--  1 www-data www-data  2323 Jun 14  2023 wp-comments-post.php
-rw-------  1 www-data www-data  3017 Sep 30  2024 wp-config.php
-rw-r--r--  1 www-data www-data  3339 Feb 23 21:20 wp-config-sample.php
drwxr-xr-x  6 www-data www-data  4096 Mar 10 23:25 wp-content
-rw-r--r--  1 www-data www-data  5617 Feb 23 21:20 wp-cron.php
drwxr-xr-x 31 www-data www-data 16384 Feb 23 21:20 wp-includes
-rw-r--r--  1 www-data www-data  2493 Feb 23 21:20 wp-links-opml.php
-rw-r--r--  1 www-data www-data  3937 Mar 11  2024 wp-load.php
-rw-r--r--  1 www-data www-data 51437 Feb 23 21:20 wp-login.php
-rw-r--r--  1 www-data www-data  8727 Feb 23 21:20 wp-mail.php
-rw-r--r--  1 www-data www-data 31055 Feb 23 21:20 wp-settings.php
-rw-r--r--  1 www-data www-data 34516 Feb 23 21:20 wp-signup.php
-rw-r--r--  1 www-data www-data  5214 Feb 23 21:20 wp-trackback.php
-rw-r--r--  1 www-data www-data  3205 Feb 23 21:20 xmlrpc.php
debian@debian:/var/www/html$
debian@debian:/var/www/html$
```